

Northbridge Financial Services

Cybersecurity Risk Assessment & Security Assurance Report

Assessment framework: NIST Cybersecurity Framework (CSF) 2.0
Assessment environment: Controlled / fictional assessment scenario
Organisation size: Approximately 250 employees
Industry: Financial Services

1. Executive Summary

This assessment reviewed the cybersecurity risks and security controls of Northbridge Financial Services Ltd, a fictional UK-based financial services organisation. The assessment considered key technology, identity, data, cloud, endpoint, supplier and incident-response risks and used NIST CSF 2.0 as the primary assessment framework.

The assessment identified 10 key cybersecurity risks. Two were rated Critical and eight were rated High using the assessment's 1–5 likelihood and 1–5 impact scoring model. The assessment also identified opportunities to strengthen access reviews, privileged access management, cloud configuration monitoring, vulnerability remediation, supplier assurance, incident response testing and recovery validation.

The remediation plan prioritises practical actions intended to reduce exposure and improve the organisation's overall security assurance position.

2. Assessment Scope

- Identity and access management
- Microsoft 365 and Azure environments
- Windows endpoints and endpoint security
- Customer and financial data
- Vulnerability and patch management
- Third-party supplier risk
- Security monitoring and logging
- Incident response
- Backup, disaster recovery and business continuity

3. Key Risk Findings

Risk ID	Risk	Score	Rating
R-001	Phishing / credential compromise	20	Critical
R-005	Exploitation of unpatched vulnerabilities	16	Critical
R-002	Excessive user privileges	15	High
R-003	Azure misconfiguration	15	High
R-004	Ransomware	15	High
R-006	Third-party supplier compromise	15	High
R-007	Sensitive data exposure	15	High

Risk ID	Risk	Score	Rating
R-008	Delayed incident response	12	High
R-009	Cloud service availability / resilience	12	High
R-010	Privileged account compromise	15	High

4. Control Assessment

The control assessment reviewed 17 security control areas across the six NIST CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond and Recover.

Area	Assessment
Governance and risk management	Partially Implemented
Asset and data management	Partially Implemented
Identity and access management	Partially Implemented
MFA and privileged access	Partially Implemented
Security awareness	Partially Implemented
Data protection	Implemented
Logging and monitoring	Partially Implemented
Endpoint security	Implemented
Incident response	Partially Implemented
Backup and recovery	Partially Implemented
Business continuity	Partially Implemented

5. Key Control Gaps

- Inconsistent MFA coverage and limited use of phishing-resistant authentication for high-risk accounts.
- Vulnerability remediation timelines are not consistently enforced.
- Access and privileged-account reviews require stronger periodic assurance.
- Azure configuration review and continuous monitoring can be strengthened.
- Third-party security assurance requires a more consistent review process.
- Incident response procedures should be tested through regular exercises.
- Backup restoration and disaster recovery arrangements require regular validation.

6. Remediation Priorities

Priority	Action	Target
Critical	Strengthen MFA / phishing-resistant authentication	0–90 days
Critical	Define vulnerability remediation SLAs and track findings	0–60 days
High	Strengthen privileged access and access reviews	0–90 days
High	Improve Azure configuration monitoring	0–90 days
High	Test backup recovery and disaster recovery	0–120 days
High	Strengthen supplier security assurance	0–120 days
High	Run incident response exercises	0–90 days

7. Security Assurance Conclusion

The assessment identified a number of established security controls, but also highlighted areas where control coverage, consistency or assurance could be improved. The highest-priority actions relate to identity protection, vulnerability management, privileged access, resilience and incident preparedness.

The remediation plan provides a practical sequence of actions that can be tracked by the relevant control owners. A follow-up assessment should be performed after remediation activities have been implemented to confirm whether the identified gaps have been addressed.

8. Disclaimer

This report was produced as part of a controlled cybersecurity risk and security assurance project using a fictional organisation and simulated assessment information. It does not represent an assessment of a real company or production environment.